Manual del administrador(a) del sistema

El administrador gestiona los **mantenedores**, la **seguridad** y el **diagnóstico**. Por diseño de mínimo privilegio **no puede leer expedientes** ni descargar sus archivos (eso corresponde a los funcionarios que participan y, en solo lectura, al auditor). Para la instalación técnica en cPanel vea el `README.md` del proyecto.

1. Menú del administrador

El menú se agrupa en **Administración** (Unidades, Usuarios, Roles y permisos, Trámites, Tipos de documento, Plantillas, Folios, Estilo y posición de firmas, Instituciones, Procesos, Codificador, Servicios PISEE, APIs e integraciones, Repositorio, Apariencia, Barra de menú) y **Seguridad y operación** (Seguridad, Registro de logs, Usuarios conectados, Conexiones y mapa, Recursos del servidor, Componentes y librerías, Diagnóstico). Cada persona ve solo lo que su rol permite; los grupos se despliegan con Enter o Espacio y se cierran con Esc.

En todos los mantenedores **no existe el borrado**: se **desactiva** (botón *Desactivar/Activar*). Cada cambio queda en la bitácora de auditoría.

2. Unidades

Cree las unidades municipales (código y nombre). Las unidades responsables de cada trámite y la unidad de cada funcionario salen de aquí.

3. Usuarios

1. **Nuevo**: ingrese **RUN** (con dígito verificador; se valida), nombres, apellidos, correo, cargo, **rol** y **unidad**.
2. Roles: los del sistema (`admin`, `funcionario`, `alcalde`, `secretario`, `auditor`, `autoridad`, `oirs`) y los **personalizados** que cree en *Roles y permisos* (§17). Use el buscador y los filtros de rol/estado para ubicar personas.
3. **Habilitado para firmar**: solo para funcionario, alcalde y secretario. Admin, auditor, autoridad y OIRS **nunca** firman.

4. **Desactivar** quita el acceso en la siguiente petición y **cierra sus sesiones abiertas**. Cambiar el rol de alguien también cierra sus sesiones (el nuevo rol rige desde el siguiente ingreso).
5. Resguardos: no puede desactivar **su propia** cuenta y siempre debe quedar **al menos un administrador activo**.
6. La columna *Último acceso* muestra el último ingreso con ClaveÚnica.

Para el primer administrador vea el README (alta por SQL). Los demás usuarios ingresan después con ClaveÚnica: **solo entra quien está registrado y activo**.

4. Trámites y servicios

Los trámites **ya no se editan como una lista del mantenedor**: cada dirección administra los suyos en **Trámites y servicios** (`/app/tramites`) con los permisos `tramites.gestionar` (crear, editar, duplicar y deshabilitar) y `tramites.publicar` (publicar y reactivar; también para editar un trámite ya publicado). Por defecto **solo el rol administrador** los tiene; para habilitar a una dirección:

1. En *Roles y permisos* cree un rol personalizado con base **funcionario**, **alcalde** o **secretario** (el auditor nunca puede recibirlos) y marque *Trámites y servicios*. Para separar funciones cree dos roles: uno que solo **gestiona** (redacta borradores) y otro que además **publica**.
2. Asigne el rol en *Usuarios*. **La persona debe tener una unidad (dirección) asignada**: administra solo los trámites cuya *dirección propietaria* es su unidad. Sin unidad no puede crear.
3. Usted (administrador) ve **todas** las direcciones y es el único que puede fijar la dirección propietaria, las direcciones responsables adicionales, el **código CPAT** (formato validado, p. ej. `PA-UNI00002-00001`; use los reales del catálogo) y el **proceso del Codificador**.

Ciclo de vida: **borrador** (no visible) → **publicado** (visible y solicitable) ↔ **deshabilitado** (no admite solicitudes nuevas; las ya ingresadas siguen su curso). Cada cambio crea una **versión inmutable** (*Historial*) y queda en la auditoría (`tramite.crear/editar/publicar/deshabilitar/reactivar/duplicar`). Los textos se guardan como **texto plano**: sin HTML, sin caracteres invisibles y sin direcciones web en el nombre; las direcciones web de la descripción se muestran como texto, sin enlace, y el sistema advierte al publicar.

Catálogo público: `/tramites` (y el buscador de la página de inicio) muestra, sin iniciar sesión, **solo los trámites publicados**; al deshabilitar o volver a borrador un trámite desaparece al instante. No muestra códigos internos. Puede ocultar o renombrar el ítem en *Barra de menú*. Cada visita se registra como `publico.tramites`/`publico.tramite` y tiene el mismo límite de consultas por minuto que la validación pública.

La solicitud llega a la bandeja de **todas** las direcciones responsables; la primera que la toma crea el expediente.

> **Archivo municipal (microformas):** sus cuatro permisos (`archivo.ver`, `archivo.gestionar`, `archivo.certificar`, `archivo.disposicion`) **no están disponibles para el rol administrador** (no lee el contenido del archivo). Cree roles personalizados con base funcionario, secretario o alcalde (la autorización de disposición solo admite secretario o alcalde) y asígnelos; para separar funciones use al menos un rol que registra y otro que certifica. La auditoría puede *ver* por defecto. El módulo guarda archivos cifrados, hash de conjunto y cadena de custodia; no reemplaza la certificación legal.

> **DocDigital:** las credenciales (Client ID y Client Secret entregados por la institución), la URL del servidor, la URL para obtener el token y las rutas de la API se configuran en *APIs e integraciones* → *DocDigital* (o en el `.env`). El secreto se guarda cifrado si la opción de secretos en BD está activa, o solo en el `.env`; **no se vuelve a mostrar**. Después use *DocDigital* → *Probar conexión*. Las credenciales de producción no deben usarse desde el ambiente de pruebas con envíos reales; si comparte credenciales por chat o correo, **rótelas** al terminar.

5. Tipos de documento y reglas de firma

Cada tipo define: código, nombre, prefijo de numeración, **si la primera firma es del alcalde/delegado**, **firmas del flujo ágil** y **firmas del flujo clásico**. Ajuste las reglas según la normativa del municipio (por defecto 1 y 2). Puede crear tipos nuevos (por ejemplo "Resolución").

6. Plantillas y formatos

Administración → Plantillas. Aquí se mantienen los **formatos oficiales** (decretos, oficios, instructivos, etc.) que el personal usa para partir sus documentos.

1. **Nueva plantilla**: nombre, **tipo de documento**, descripción (se muestra en el catálogo) y contenido.
2. **¿Quién puede verla?** *Toda la municipalidad*, o **solo las direcciones o unidades que marque** (por ejemplo Salud, Educación u otra). Para que exista una dirección en la lista debe estar creada en *Unidades*. Los administradores y el auditor ven todos los formatos; el resto, solo

los de toda la municipalidad y los de su unidad.

3. **Editor completo**: menús (Editar, Ver, Insertar, Formato, Tabla, Herramientas, Ayuda), estilos de párrafo y títulos, tipo y tamaño de letra, negrita/cursiva/subrayado/tachado, subíndice/superíndice, colores de texto y de fondo, alineación (incluida justificada), listas, sangría e interlineado, **tablas** (filas, columnas, combinar celdas, bordes, anchos), **imágenes**, enlaces, caracteres especiales, línea horizontal, fecha, buscar y reemplazar, bloques visibles, pantalla completa, vista previa, código fuente y ayuda (Alt+0).
4. **Imágenes**: botón de imagen → pestaña *Cargar* (o arrastre/pegue la imagen en el editor). PNG, JPG o WebP de hasta 2 MB; se reescalan a 1600 px, se **re-codifican** (sin metadatos) y se guardan **cifradas** en el repositorio. Complete el texto alternativo. No se aceptan SVG, GIF ni imágenes de otros sitios. Las imágenes cargadas no se eliminan (los documentos ya emitidos pueden usarlas).
5. **Variables**: botón *Variables* → inserta campos como `{{fecha}}`, `{{expediente}}`, `{{folio}}`, `{{solicitante_nombre}}`, `{{solicitante_run}}`, `{{tramite}}`, `{{unidad}}`, `{{institucion_origen}}`, `{{asunto_origen}}`, `{{folio_docdigital}}`. Al crear el documento se reemplazan (con los valores escapados).
6. **Salto de página**: botón dedicado; en el PDF inicia una página nueva.
7. **Historial**: cada guardado con cambios crea una **versión inmutable**. Desde *Historial de versiones* puede ver cualquier versión y **restaurarla** (se crea una versión nueva).
8. **Duplicar** crea una copia **inactiva** para adaptar un formato; **Desactivar** la retira del catálogo sin borrarla.
9. **Ver** muestra la vista previa con datos de ejemplo y un **PDF de ejemplo**.

El contenido se **sanitiza en el servidor** con una lista blanca (se eliminan scripts, estilos peligrosos, iframes, formularios e imágenes externas), independiente de lo que haga el navegador.

7. Codificador de instituciones y procesos

Menú **Codificador**:

1. Configure `CODIFICADOR_INSTITUCION_CODIGO` con el código de la Municipalidad.
2. **Importe CSV** (UTF-8, con cabecera): instituciones `codigo,nombre,tipo,codigo_padre`; procesos `codigo,nombre,institucion_codigo`. Los códigos existentes se actualizan; las filas inválidas se informan.
3. Con `CODIFICADOR_MODE=api` puede **sincronizar por API** (formato A VALIDAR).
4. Revise y edite en **Instituciones** y **Procesos**.

Las instituciones del catálogo son las opciones de **destinatario** al despachar por DocDigital.

7 bis. Casilla Única e inicio dual

- **Casilla Única:** se configura en *Administración → APIs e integraciones → Casilla Única / Notificador* (modo, URL, token u OAuth2 Client ID/Secret/URL del token, solo https). El contrato de la API está **A VALIDAR**; mantenga **Outbox** hasta validarlo. Los funcionarios gestionan las notificaciones en el menú **Casilla Única**; el permiso `casilla.gestionar` (probar conexión y reintentar) se asigna en *Roles y permisos* (por defecto, secretario y admin).
- **Inicio dual:** los funcionarios que también son vecinos eligen su espacio al ingresar. Se desactiva con `SGD_ESPACIO_DUAL=false` en `.env`.

7 ter. Roles Autoridad y OIRS

- **Autoridad:** consulta el *Seguimiento de solicitudes* (por RUN, fechas, dirección, etapa o trámite). **OIRS:** usa el *Panel OIRS* (estado, responsables, plazos vencidos y por vencer). Ambos son **solo lectura**: no operan expedientes, no firman y no ven documentos.
- Cree las personas en *Usuarios* con ese rol y sin unidad. Permisos: `seguimiento.consultar` (autoridad, alcalde y auditor por defecto) y `oirs.ver` (OIRS). El administrador no los recibe.
- **Plazos:** días corridos por defecto; `SGD_PLAZOS_HABILES=true` cuenta lunes a viernes (sin feriados) y `SGD_PLAZOS_AVISO_DIAS` define «por vencer» (3). Ver `docs/NORMATIVA.md` §8 (A VALIDAR).
- Todo acceso queda en la bitácora con el RUN enmascarado.

8. DocDigital

Todo se configura en el `.env` (ver README): `DOCDIGITAL_MODE` (`outbox` por defecto; `demo` para DemoDoc; `prod`), URL, token y rutas de la guía API MW V2, y `DOCDIGITAL_UNIDAD_RECEPCION` (unidad que recibe lo entrante).

- Requisitos de la Secretaría de Gobierno Digital: alta de la institución, **Administrador Principal** e interlocutor.
- El sistema solo envía PDF con **firma electrónica avanzada real**.
- Cada comunicación recibida crea un expediente con identificador único en la unidad receptora (revise que esa unidad exista y esté activa).

- El cron ejecuta `docdigital:sincronizar` cada 10 minutos. Si falla, el sistema no pierde estado: reintente o revise credenciales.

9. PISEE

1. Adhiera a los términos y condiciones de PISEE e instale el nodo de interoperabilidad (Gobierno Digital).
2. Configure en `.env` el nodo (`PISEE_BASE_URL`, https), la cabecera de identificación, el certificado de cliente y la CA; active `PISEE_MODE=api`.
3. En **Servicios PISEE** registre **solo** los servicios autorizados: código, nombre, institución, **ruta** relativa (validada), método y el parámetro que lleva el RUN. Es una **lista blanca**.
4. Cada consulta exige finalidad, solo al RUN del solicitante del expediente, y queda auditada.

10. Seguridad y auditoría

Menú **Seguridad**:

- **Verificar cadena de auditoría**: comprueba la cadena HMAC. Debe decir "Cadena íntegra". Si está **rota**, no borre nada: registre un incidente y siga el plan de respuesta (`docs/INCIDENTES.md`).
- **Incidentes**: registre incidentes (título, descripción sin datos personales, severidad) y marque si es **reportable al CSIRT Nacional**; registre los hitos: alerta temprana, segundo reporte e informe final (plazos A VALIDAR en la normativa vigente).
- **Últimos eventos**: login, firmas, accesos denegados, CSRF fallidos, errores, etc.

11. Diagnóstico

Diagnóstico revisa extensiones PHP, versión, permisos del directorio de archivos, que no haya modos *mock*, `APP_DEBUG`, HTTPS, claves y la cuenta de servicio de Google. Todo debe estar en "OK" antes de producción.

12. Correo institucional (Google Workspace)

El correo sale por la **Gmail API** con una cuenta de servicio y delegación de dominio (alcance `gmail.send`, buzón `no-responder@...`). Verifique el envío creando una notificación por correo en un expediente de prueba. Rotación de clave: README y `docs/INCIDENTES.md`.

13. Respaldo y restauración

Respalde la base de datos y `sgd_storage` (cifrado) a diario y guarde las **claves** (`APP_KEY`, `FILE_ENCRYPTION_KEYS`, `AUDIT_HMAC_KEY`) por separado. **Pruebe la restauración** periódicamente. Detalle en el README.

14. Accesibilidad

Puede cambiar `SGD_ACCESIBILIDAD_CONTACTO` (correo que aparece en la declaración de accesibilidad). Revise periódicamente el canal de contacto y atienda los reportes.

15. Apariencia: logo, colores, encabezado y pie

Administración → Apariencia.

- **Logo:** suba PNG, JPG o WebP (hasta 1 MB, mínimo 32×16 px). El sistema lo **re-codifica** (elimina metadatos) y rechaza SVG por seguridad. Escriba el **texto alternativo** (obligatorio si el logo se muestra) y su alto en pantalla.
- **Colores:** cada par texto/fondo se valida con **contraste ≥ 4,5:1** (WCAG AA). Si el contraste no alcanza, el sistema no guarda y le indica el par que falla.
- **Encabezado:** título y subtítulo. **Pie:** texto, texto legal y enlaces (rutas internas `/…` o direcciones `https://`).
- **Restablecer** vuelve a los colores y textos originales sin borrar el logo.

16. Barra de menú

Administración → Barra de menú. Cambie el nombre, el orden y la visibilidad de los ítems del sistema; los marcados como protegidos (Inicio, Bandeja, Ayuda…) no se pueden ocultar. Agregue **enlaces propios** por área (público, ciudadano, funcionarios), opcionalmente solo para ciertos roles y con apertura en pestaña nueva. **El menú solo cambia la navegación: no otorga ni quita permisos.**

17. Roles y permisos

Administración → Roles y permisos. Los 7 roles del sistema son de solo lectura (puede ver sus permisos). Para crear un rol:

1. **Nuevo rol**: clave (minúsculas, números y `_`), nombre y **rol base**. El rol base fija las reglas de negocio (quién puede firmar, ser asignado a expedientes, etc.) y el **techo** de permisos.
2. Marque los permisos necesarios. Los no admitidos por el rol base aparecen deshabilitados; `roles.gestionar` y `delegaciones.crear` están reservados a los roles del sistema.
3. Los permisos *Trámites y servicios* (`tramites.*`) son **opcionales**: ningún rol del sistema (salvo administrador) los trae; se entregan solo mediante roles personalizados (vea la sección 4).
4. Asigne el rol en *Usuarios*. Al editar permisos, las sesiones de quienes tienen ese rol se cierran para aplicar los cambios.
5. No se puede cambiar la base ni eliminar un rol con usuarios asignados; desactívelo solo si no tiene usuarios activos.

18. APIs e integraciones

Administración → APIs e integraciones. Para cada servicio (ClaveÚnica, FirmaGob, casilla, Gmail, DocDigital, PISEE, Codificador, asistente IA, repositorio) puede ver el estado efectivo, editar URL/modo, **probar la conexión** y **volver a la configuración del `.env`**. Los secretos (tokens, claves) **nunca se muestran**; por defecto solo se configuran en el `.env`. En producción están prohibidos los modos simulados.

19. Folios por tipo de documento

Administración → Folios. Por tipo defina el **formato** con las fichas `{PREFIJO}`, `{TIPO}`, `{N}`, `{AAAA}`, `{AA}` (p. ej. `{PREFIJO} N° {N}/{AAAA}`), los dígitos, si el número **se reinicia cada año** o es continuo, y el número inicial. El folio se asigna al finalizar el documento y **no cambia nunca**. El contador solo se puede ajustar hacia arriba.

20. Estilo y posición de las firmas

Administración → Estilo y posición de firmas. Defina estilos (colores con contraste ≥ 4,5:1, tamaño, textos) y posiciones (primera página con coordenadas en mm, o al final del texto con alineación) por tipo de documento y número de firma. Use **Vista previa** para generar un PDF de prueba. El sello es la representación visual en la copia pública; la validez la da la firma electrónica del PDF firmado.

21. Repositorio de documentos (Google Drive)

Administración → Repositorio. Los documentos pueden guardarse en el disco del servidor o en una **unidad compartida de Google Drive** (pasos de preparación en el README). Siempre se guardan **cifrados**.

1. Configure el modo y los identificadores; pulse **Probar conexión** (debe indicar éxito en todos los pasos).
2. **Migrar** mueve en lotes los archivos locales a Drive; cada archivo se verifica antes de borrar el original local.
3. **Verificar integridad** comprueba una muestra descargando y validando el contenido; también se ejecuta a diario.
4. Si Drive no responde, las subidas **fallan** con aviso (no se guardan en otra parte). Reintente cuando se restablezca.
5. Conserve un **respaldo de las claves de cifrado** (`sgd_secrets`): sin ellas los archivos no se pueden recuperar.

22. Registro de logs

Seguridad y operación → Registro de logs. Filtre por fecha, acción (empieza con), rol, RUN exacto, entidad, IP o sensibilidad. Los RUN se muestran enmascarados. **Exportar CSV** (quien tenga el permiso) deja un registro sensible en la bitácora. **Log de aplicación** muestra las últimas líneas del log técnico con datos personales y secretos redactados. La verificación de la cadena HMAC está en *Seguridad*.

23. Usuarios conectados

Seguridad y operación → Usuarios conectados. Lista las sesiones con actividad reciente (funcionarios y ciudadanos con RUN enmascarado), su IP, navegador, inicio y última actividad. **Cerrar sesión** fuerza la salida de esa persona (queda auditado); su propia sesión se cierra con *Salir*.

24. Recursos del servidor

Seguridad y operación → Recursos del servidor. Muestra CPU, memoria (RAM), disco, memoria de PHP y OPcache, tamaño de la base de datos, archivos del repositorio, sesiones activas y cola de trabajos, cada uno con su **estado en texto** (Normal, Atención desde 70 %, Crítico desde 90 %). Abajo hay un **histórico** (24 horas, 7 o 30 días) con gráficos y la tabla de datos de cada uno. Si el hosting informa límites de su plan, se usan esos; si algo no puede leerse, dice «sin dato». Si no hay gráficos,

revise que el cron de cPanel ejecute `schedule:run` cada minuto (las muestras se toman cada 5 minutos).

Qué hacer: *Crítico* en disco → depure respaldos/logs o amplíe el plan; *Crítico* en memoria o CPU sostenido → revise la cola y consulte al proveedor de hosting; *Cola con fallidos* → revise el registro de logs.

25. Componentes y librerías

Seguridad y operación → Componentes y librerías. Inventario con las versiones de PHP, Laravel, base de datos y bibliotecas del sistema, de **cada librería PHP** (con licencia) y de **cada activo front-end** (jQuery, Bootstrap, TinyMCE, gob.cl, tipografías, con tamaño y huella SHA-256). La sección **Recursos externos (CDN)** debe decir «Sin CDN ni recursos externos»; si detecta alguno, lista el archivo y la dirección. **Descargar inventario (JSON)** entrega todo en un archivo para auditorías. Para vulnerabilidades conocidas use `composer audit`.

26. Firmas electrónicas en archivos cargados

Junto a cada PDF (expediente, anexos, comunicaciones de DocDigital) verá si está **firmado electrónicamente**. Use *Ver firmas* para ver firmante, emisor, fecha, vigencia del certificado, integridad y cobertura. «Firma inválida o documento alterado» significa que el contenido cambió después de firmarse. «Confianza del emisor no verificada» aparece mientras no se configure `SGD_FIRMA_CA_BUNDLE` (CA de prestadores acreditados). Esta verificación **no reemplaza** la validación legal ni revisa revocación de certificados.

27. Conexiones y mapa

Seguridad y operación → Conexiones y mapa. Muestra **de dónde llegan** las conexiones al sistema (*entrantes*) y **a qué servicios se conecta** el sistema (*salientes*: ClaveÚnica, FirmaGob, DocDigital, Google, etc.).

- **Filtros:** últimas 24 horas, 7 o 30 días; entrantes, salientes o ambas.
- **Mapa por país:** más oscuro = más conexiones (escala logarítmica). Pase el mouse o use la **tabla «Conexiones por país»**, equivalente para lectores de pantalla. «Red interna / local» agrupa direcciones privadas.

- **Ranking de IP:** las 20 IP con más conexiones, su país, errores y el tipo de uso (público, ingreso, ciudadanos, funcionarios). Una **proporción alta de errores** (resaltada) con muchas conexiones suele ser un **escaneo automatizado**; para bloquear una IP use el firewall del hosting (cPanel → *IP Blocker*).
- **Destinos salientes:** servicios con más conexiones desde el sistema y sus errores (útil para detectar caídas de integraciones).
- **Privacidad:** solo se guardan contadores por hora (IP o servidor de destino y tipo de ruta); **no** se guarda la dirección visitada ni el contenido. Las IP son datos personales: el panel es solo para administración y auditoría y los datos se eliminan a los 90 días.
- La ubicación por IP es **aproximada** (por país). VPN, proxy o redes móviles pueden aparecer en otro país.

28. Seguridad del contenido (plantillas, documentos e IA)

El sistema **no ejecuta código** que alguien pegue en una plantilla, un documento o la respuesta de la IA: elimina scripts, formularios, marcos, estilos peligrosos, enlaces a otros sitios sin protocolo y caracteres invisibles o de inversión de texto, tanto al guardar como al mostrar y al generar el PDF. Las imágenes solo pueden venir de la biblioteca interna. Las respuestas de la IA se muestran como **texto**; si traían marcado, enlaces o direcciones, aparece una advertencia y queda registrado `llm.salida_sospechosa` (en el registro de logs). Aun así, **toda redacción de la IA debe ser revisada por una persona**.

29. Problemas frecuentes

Problema	Qué hacer
Un funcionario no puede ingresar	Verifique RUN, que esté **activo** y el rol.
La aplicación no arranca en producción	Revise `.env`: debug, https, modos mock, claves, JSON de la cuenta de servicio.
Notificaciones por correo "fallidas"	Cron activo, cola, credenciales Google, delegación de dominio.
No llegan comunicaciones de DocDigital	Modo API, credenciales, unidad receptora, cron.
Alerta de cadena rota	Plan de incidentes: preservar evidencia, no modificar.